MODULE 22 · DOMAIN 6 - GOVERNANCE, RISK AND RESPONSIBLE USE

Data Sensitivity, Privacy and Regulation

Classify first, send only what the task needs, redact or pseudonymise, UK GDPR in plain terms, and what settings can and cannot do.

DOMAIN 6 of 7 EXAM WEIGHT 15% MODULE 22 of 33

admin@sthithapragna.com

Classify first. Then send only what the task needs.

Halden's four data classes

CLASS	EXAMPLES	WITH CLAUDE
Public	Website text, published case studies	Fine
Internal	Rotas, process documents, internal guides	Fine in approved tools
Confidential	Client contracts, pricing, tender responses	Approved tools, need-to-know Projects, minimised
Restricted	Payroll, health, disciplinary investigations, government ID numbers	Never entered into any AI tool

ON THE EXAM

The policy decides, not the urgency of the task. Restricted means no, and you find another route.

What counts as sensitive

- **Identity numbers:** passport, driving licence, National Insurance numbers.
- **Financial details:** payment card numbers, bank accounts, payroll.
- **Health and other special category data,** plus investigation and disciplinary material.
- **Contact details of individuals:** personal phone numbers, home addresses, personal email.

> THE TIEBREAKER
>
> If losing it would harm a person, treat it as sensitive, whatever the spreadsheet column is called.

UK GDPR in plain terms: the seven principles

PRINCIPLE	IN PLAIN TERMS
Lawfulness, fairness and transparency	A valid reason, used fairly, and people are told
Purpose limitation	Use it for the purpose it was collected for
Data minimisation	Only what is necessary for that purpose
Accuracy	Keep it correct and up to date
Storage limitation	Do not keep it longer than needed
Integrity and confidentiality	Keep it secure
Accountability	Be able to show you complied

ON THE EXAM

Data minimisation is the principle the exam leans on: "limited to what is necessary".

Special category data, and a 2025 change

- **Special category data:** racial or ethnic origin, political opinions, religious or philosophical beliefs, trade union membership.
- **Also:** genetic data, biometric data used for identification, health, sex life and sexual orientation.
- **Criminal offence data** is not special category data, but has its own rules and safeguards.
- **The Data (Use and Access) Act 2025** amended UK GDPR in stages; the regulator's guidance is under review.

> THE TIEBREAKER
>
> Your data protection officer owns the legal call. Your job is to recognise the data and ask.

Before any data goes to Claude

01
Classify
Public, Internal, Confidential, Restricted.

02
Check policy
What this class allows, and where.

03
Minimise
Remove what the task does not need.

04
De-identify
Redact or pseudonymise what remains.

05
Then prompt
And check the output for leaks.

ON THE EXAM

Every step happens before upload. After upload, it is too late to minimise.

Redact, anonymise or pseudonymise?

TECHNIQUE	WHAT IT DOES	STILL PERSONAL DATA?
Redact	Removes the detail, like blacking out a line	Not the removed part
Anonymise	No one can be re-identified, even by combining data	No, if it is truly anonymous
Pseudonymise	Swaps names for codes; the key is kept separately	Yes: the key can reverse it

ON THE EXAM

Pseudonymised data is still personal data. The policy still applies.

Quirk 11: phone numbers in the feedback

- **The export:** client comments mixed with site staff names and mobile numbers.
- **The task:** find themes in the comments. Names and numbers add nothing.
- **The fix:** delete those columns before upload; check free-text comments for stray numbers too.
- **Not a fix:** uploading everything and asking Claude to ignore the numbers.

> THE SIGNAL
>
> Remove it before upload. Asking Claude to ignore it means it has already been shared.

Quirk 13: the investigation

- **The request:** summarise notes from an ongoing disciplinary investigation.
- **The policy:** investigation material is Restricted. It may not be entered into any AI tool.
- **Not workarounds:** incognito, pseudonymised names, or "please do not retain this".
- **Approved routes:** a blank report template from the published procedure, a process checklist, or a question to the data protection officer.

> ON THE EXAM
>
> When the policy says no, follow it, and find an approved route to the same goal.

Data terms, retention and settings

SITUATION	WHAT HAPPENS
Consumer plans: Free, Pro, Max	You choose whether chats help train models; retention depends on that choice
Commercial plans: Team, Enterprise, API	Chats are not used to train models
Deleting a chat	Gone from history at once; removed from back-end systems within 30 days
Incognito chat	Not saved to history or Memory; still retained for a period for safety

ON THE EXAM

Settings reduce risk. They never change what the policy allows.

Controls, and things that only sound like controls

- **Real controls:** classification, policy, minimisation, the plan's data terms, admin settings.
- **Not a control:** "please do not retain this" in a prompt. It changes nothing about storage.
- **Incognito and Memory help with Confidential work:** nothing saved to Memory, nothing found by search.
- **Memory already leaves out** government IDs and financial account numbers, and sensitive topics by default.

> THE TIEBREAKER
>
> A setting can make Confidential work tidier. Nothing makes Restricted data allowed.

Data traps

THE TRAP	WHY IT FAILS
Uploading first, minimising later	Already shared; too late
"Ignore the phone numbers"	Claude has still received them
Calling pseudonymised data anonymous	Still personal data; policy still applies
Incognito for Restricted data	A setting does not override the policy
"Please do not retain this"	Not a control
Urgency as a reason to skip classification	The policy decides, not the deadline

ON THE EXAM

Every trap treats a promise or a setting as if it were a control.

> Halden's marketing manager wants Claude to draft a case study from a client satisfaction survey. The survey names the client and its staff.
>
> Some client contracts restrict how Halden may refer to clients in publicity.

What should she do first?

A Classify the data and check the policy, including whether client contracts allow the client to be identified

B Upload the survey and ask Claude to anonymise the clients in its output

C Upload it with an instruction that Claude must not retain anything

D Upload it in an incognito chat

◆ PAUSE AND DECIDE

What should she do first?

A Classify the data and check the policy, including whether client contracts allow the client to be identified

Classify and check policy and contracts before anything is shared.

B Upload the survey and ask Claude to anonymise the clients in its output

Shares first; anonymising the output is too late.

C Upload it with an instruction that Claude must not retain anything

An instruction is not a control.

D Upload it in an incognito chat

A setting does not answer what the contract allows.

THE SIGNAL

Named people and a contract restriction: classify and check before anything moves.

> Quirk 11: Halden's client feedback export mixes client comments with site staff names and mobile numbers.
>
> Customer success wants Claude to find the main themes in the comments.

What is the best approach?

A Upload the whole export and tell Claude to ignore names and phone numbers

B Delete the name and phone-number columns before upload, check comments for stray numbers, then analyse

C Upload the whole export in an incognito chat

D Upload it, and ask Claude to delete the phone numbers after the analysis

◆ PAUSE AND DECIDE

What is the best approach?

A Upload the whole export and tell Claude to ignore names and phone numbers

Claude has still received the numbers.

B Delete the name and phone-number columns before upload, check comments for stray numbers, then analyse

Minimise before upload; themes need only the comments.

C Upload the whole export in an incognito chat

A setting; the numbers are still shared.

D Upload it, and ask Claude to delete the phone numbers after the analysis

Shared first, and Claude cannot unshare it.

THE SIGNAL

The task needs comments only: remove everything else before upload.

> Quirk 13: a Halden HR partner wants Claude to summarise her notes from an ongoing disciplinary investigation.
>
> Halden's AI policy classes investigation material as Restricted.

What is the right response?

A Paste the notes into an incognito chat, since nothing is saved to history

B Paste the notes, adding "please do not retain this"

C Do not enter the notes; use Claude only for material without Restricted data, such as a blank report template, and ask the data protection officer if unsure

D Replace names with codes, then paste the rest of the notes

◆ PAUSE AND DECIDE

What is the right response?

A Paste the notes into an incognito chat, since nothing is saved to history

A setting does not override a Restricted classification.

B Paste the notes, adding "please do not retain this"

Not a control.

C Do not enter the notes; use Claude only for material without Restricted data, such as a blank report template, and ask the data protection officer if unsure

Follow the policy; find an approved route.

D Replace names with codes, then paste the rest of the notes

Pseudonymised, it is still investigation material.

THE SIGNAL

Restricted means no AI tool: follow the policy, and find an approved route.

> Halden's customer success team wants to analyse complaint patterns by site. The records include client contacts' names.
>
> They replace each name with a code, and keep the code key in a separate locked file.

What has the team done, and what follows from it?

A Anonymised the data, so it is no longer personal data

B Redacted the data, so nothing identifying remains

C Encrypted the data, so the policy no longer applies

D Pseudonymised the data, so it is still personal data and the policy still applies

◆ PAUSE AND DECIDE

What has the team done, and what follows from it?

A Anonymised the data, so it is no longer personal data

The key can reverse it, so it is not anonymous.

B Redacted the data, so nothing identifying remains

Nothing was removed; names were swapped for codes.

C Encrypted the data, so the policy no longer applies

Swapping names for codes is not encryption.

D Pseudonymised the data, so it is still personal data and the policy still applies

Codes plus a separate key: pseudonymised, still personal.

THE SIGNAL

Codes with a key kept elsewhere: pseudonymised, and still personal data.

> A Halden supervisor's incident report about a slip at a client office will be summarised for the client.
>
> The report holds the worker's National Insurance number and medical details, the time, the site address, and what happened.

Which two items should be removed before Claude drafts the client summary? Choose two.

A The injured worker's National Insurance number

B The time of the incident

C The business address of the client site

D The injured worker's medical details

E The description of the wet floor and missing sign

◆ PAUSE AND DECIDE

Which two items should be removed before Claude drafts the client summary? Choose two.

A The injured worker's National Insurance number

A government ID number: Restricted, and not needed.

B The time of the incident

Needed for the summary, and not sensitive.

C The business address of the client site

A business address the client already knows.

D The injured worker's medical details

Health data: Restricted, and not needed.

E The description of the wet floor and missing sign

The substance of the report.

THE SIGNAL

Restricted and unnecessary: the ID number and the health details come out.

> Halden uses Claude on the Team plan. A manager worries that client details in chats will be used to train Anthropic's models.

Which statement is accurate?

A On commercial plans such as Team, chats are not used to train models, and the data policy still applies

B Every chat trains models unless it is incognito

C Turning on the model improvement setting stops training

D Deleting each chat afterwards is the only way to stop training

◆ PAUSE AND DECIDE

Which statement is accurate?

A On commercial plans such as Team, chats are not used to train models, and the data policy still applies

Commercial terms: no training. Classification still applies.

B Every chat trains models unless it is incognito

Wrong for commercial plans.

C Turning on the model improvement setting stops training

That consumer setting allows training; it does not stop it.

D Deleting each chat afterwards is the only way to stop training

Training is not the issue on Team; deletion is about history.

THE SIGNAL

Team is a commercial plan: no training. The policy still governs what goes in.

> A Halden finance analyst says: "I'll paste the payroll file in to check the overtime totals, but I'll tell Claude not to keep it."

What is the best response?

A That is fine, because the instruction will stop Claude keeping the data

B An instruction is not a control, and payroll is Restricted, so it must not be entered at all

C That is fine, as long as it is done in an incognito chat

D That is fine, as long as the chat is deleted afterwards

◆ PAUSE AND DECIDE

What is the best response?

A That is fine, because the instruction will stop Claude keeping the data

A request changes nothing about storage.

B An instruction is not a control, and payroll is Restricted, so it must not be entered at all

Not a control, and Restricted data is never entered.

C That is fine, as long as it is done in an incognito chat

A setting does not override the policy.

D That is fine, as long as the chat is deleted afterwards

Deleting afterwards means it was entered.

THE SIGNAL

Restricted data, protected by a promise: the promise is not a control.

A Halden operations manager wants Claude to analyse a spreadsheet of site visit records that include staff names.

(1) Write the prompt and run the analysis.

(2) Classify the data.

(3) Remove columns the analysis does not need.

(4) Check what the AI policy allows for that class.

(5) Pseudonymise the staff names that remain.

What is the correct order?

A 4, 2, 3, 5, 1

B 2, 3, 4, 5, 1

C 2, 4, 3, 5, 1

D 2, 4, 5, 3, 1

◆ PAUSE AND DECIDE

What is the correct order?

A 4, 2, 3, 5, 1

Checks the policy before knowing the class.

B 2, 3, 4, 5, 1

Removes data before checking what is allowed.

C 2, 4, 3, 5, 1

Classify, check, minimise, de-identify, then prompt.

D 2, 4, 5, 3, 1

Pseudonymises columns that should simply be removed.

THE SIGNAL

Classify, check, minimise, de-identify, then prompt.

In five lines

- **Classify first;** the policy decides. Restricted is never entered into any AI tool.
- **Minimise before upload:** only what is necessary. Asking Claude to ignore data is too late.
- **Pseudonymised is still personal data;** only truly anonymous data is not.
- **Commercial plans do not train on chats;** settings reduce risk but never override policy.
- **"Please do not retain this" is not a control.** When the policy says no, find an approved route.

COMING UP

Next: AI policy and governance.